

خارطة قرار المنافذ الرئيسية

مرجع بصري يربط: الفحص -> تحديد الخدمة -> الاستطلاع -> الربط -> الوصول -> إعادة الاستطلاع.



شجرة قرار في صفحة واحدة

اتبع الخدمة والدليل، وليس استغلالاً محفوظاً.

الهدف

اكتشف المنافذ

nmap -Pn -p- TARGET

فصل ما وجدته

nmap -sC -sV -p PORTS TARGET

اكتب سؤالاً واحداً

ما المعلومة التالية التي أحتاجها؟

سطح الويب

تقنية -> مسارات/نطاقات -> مصادقة/مدخلات
-> اختبار مناسب.

ابداً: Browser, curl, Burp, Gobuster/ffuf.

Windows / AD

مشاركات/مستخدمون/توقيع/دومين -> ملفات أو
بيانات دخول -> وصول متحقق.

ابداً: smbclient, enum4linux-ng, NetExec.

الوصول البعيد

Banner/حالة المصادقة -> بيانات دخول أو مفتاح
معروف -> جلسة.

SSH, FTP, RDP, WinRM, VNC

معلومات الشبكة

سجلات/مجتمع/Exports -> أسماء، مستخدمون،
مسارات، أهداف جديدة.

dig, snmpwalk, rpcinfo, showmount

خدمات البيانات

مصادقة/إعدادات/قواعد بيانات -> اربط النتائج
بالتطبيق.

mysql, psql, redis-cli, curl

خدمة متخصصة

حدد المنتج والإصدار والإعدادات أولاً، ثم ابحث عن
تطابق دقيق.

Docker, AJP, RMI, Rsync, MQ

كل فرع يرجع إلى نفس الحلقة: نتيجة -> دخول/استغلال -> موطئ قدم -> إعادة استطلاع -> خدمة أو مسار جديد.

اجمع المنافذ حسب دلالتها

هذه مؤشرات للمسار فقط. إذا ظهرت الخدمة على منفذ غير معتاد فبصمة الخدمة هي المرجع.

سطح الويب

80, 443, 8000, 8080, 8443, 8888

افتح كل منفذ ويب وقارن التطبيقات والنطاقات والمصادقة وواجهات API ولوحات الإدارة.

Windows / AD

135, 139, 445, 3389, 5985/5986

إذا ظهر أيضاً 53 أو 88 أو 389 أو 464 أو 636 أو 3268 ففكر في سياق الدومين.

Linux / وصول بعيد

21 FTP, 22 SSH, 23 Telnet, 873 Rsync

ابحث عن الوصول المجهول والملفات المكشوفة والمفاتيح وبيانات الدخول المتحققة.

معلومات الشبكة

53 DNS, 111 RPC, 161 SNMP, 2049 NFS

قد تكشف أسماء مضيفين ومستخدمين وExports وواجهات ومسارات وأهدافاً جديدة.

البريد والهوية

25, 110, 143, 88, 389/636

الBanner وسياق التسمية وبيانات الدخول قد تكشف بنية المستخدمين والدومين.

قواعد البيانات

1433, 3306, 5432, 6379, 27017

تحقق من المصادقة والإعدادات ثم اربط Connection Strings بملفات الويب أو التطبيق.

القاعدة: المنفذ -> الخدمة -> الإصدار/الإعداد -> الاستطلاع -> النتيجة -> الوصول. لا تنتقل من رقم منفذ مباشرة إلى استغلال.

خارطة قرار سطح الويب

عامل كل منفذ HTTP/HTTPS كتطبيق مستقل إلى أن يثبت العكس.

1	افتح وحدد التقنية Browser, Headers, TLS, والتقنية.	السؤال ما التطبيق أو الإطار الموجود فعلاً؟	ابدأ -I, curl, WhatWeb, Browser.
2	اكتشف المحتوى مجلدات، ملفات، نطاقات افتراضية، ومسارات بديلة.	السؤال هل يوجد سطح آخر أو وظيفة مخفية؟	ابدأ Gobuster / ffuf.
3	افهم المدخلات مصادقة، أدوار، API, Upload, Parameters, Sessions.	السؤال ماذا يتحكم فيه كل Input؟	ابدأ Burp Proxy / Repeater.
4	اختبر الفئة المناسبة بعد فهم السلوك، لا قبل ذلك.	السؤال أي فئة ثغرات تطابق الدليل؟	أمثلة SQLi, XSS, file handling, auth flaws.
5	اربط النتائج hostname -> vhost ; Config -> DB files -> creds	السؤال أي خدمة جديدة تفتحها هذه النتيجة؟	العودة تحقق -> وصول -> إعادة استطلاع.

افتح كل منفذ ويب

لا تشغيل كل الأدوات دفعة واحدة

عامل الـ vhost كتطبيق مستقل

خارطة SMB وسياق الدومين

حدد أولاً: هل أمامك جهاز Windows مستقل أم سياق Domain أوسع؟

إذا كان 139 / 445 مفتوحاً

مؤشر قوي على Domain Controller

SMB

اسأل
Anonymous
/Users
Shares
Signing
Domain
OS/Version

ابدأ
smbclient -L
enum4linux-ng
.NetExec

ابحث عن المجموعة

53 DNS · 88 Kerberos · 135 RPC · 139 SMB · 389 LDAP · 445 SMB ·
464 kpasswd · 636 LDAPS · 3268 GC

الدليل المهم

Share مقروء - Config/Backup/Key - بيانات دخول أو Hostname -
تحقق على خدمة موجودة فعلاً.

ثم اسأل

ما اسم الدومين وسياق التسمية؟ من المستخدمين المعروفون؟ وما الخدمات التي
تقبل بيانات دخول متحققة؟

المسار: استطلاع - تثبيت السياق - ملفات/مستخدمون/بيانات دخول - تحقق على SMB/RDP/WinRM/Web/DB - إعادة استطلاع. ابحث عن ثغرة فقط بعد
تطابق المنتج والإصدار والإعداد.

قنوات الوصول ومصادر الملفات

تزداد قيمة هذه الخدمات عندما تعطيك نتيجة سابقة بيانات دخول أو مفتاحاً أو مساراً أو اسم ملف.

FTP - 21

Anonymous؟ ملفات مفيدة؟
Backup/Config؟ صلاحية رفع؟
ابدأ: ftp / Nmap NSE

SSH - 22

استخدمه بعد العثور على مفتاح أو
كلمة مرور، وطابق المستخدم
الصحيح.
ابدأ: ssh

Telnet - 23

اقرأ الBanner، واختبر بيانات
معروفة/افتراضية فقط عند وجود
مبرر.
ابدأ: telnet / nc

RDP - 3389

وصول رسومي بعيد عند توفر بيانات
Windows صحيحة.
ابدأ: xfreerdp

WinRM - 5985/5986

Shell على Windows باستخدام
بيانات دخول متحققة.
ابدأ: evil-winrm / NetExec

VNC - 5900

تحقق من حالة المصادقة والبيانات
المعروفة، وتعامل معه كقناة وصول.
ابدأ: vncviewer

NFS - 111 + 2049

الExports قد تكشف Home
directories أو Configs أو
مفاتيح SSH.
ابدأ: rpcinfo / showmount

Rsync - 873

اعرض Modules؛ القراءة المجهولة
قد تكشف Configs أو Keys.
ابدأ: rsync

اختصار الربط: ملف/بيانات دخول/مفتاح مفيد -> تحقق من الوصول -> ادخل الجلسة -> استطلع الجلسة الجديدة من البداية.

خدمات غنية بالمعلومات وقواعد البيانات

خدمة صغيرة قد تغير المسار بالكامل إذا كشفت أسماء أو مستخدمين أو Exports أو Routes أو بيانات دخول.

معلومات الشبكة

خدمات البيانات

DNS 53	.Records .Hostnames Zone، Vhosts Transfer عند ملأته.	ابداً: dig.	1433 / 3306	:MSSQL / MySQL إصدار، مصادقة، وقواعد بيانات عند توفر .Credentials	.Native client
SNMP 161/ UDP	.System، Users Routes، Interfaces عند وجود Community معروفة/ضعيفة.	ابداً: snmpwalk.	5432 / 6379	/ PostgreSQL Redis: مصادقة، DBs، INFO/Config .exposure	.psql / redis-cli
SMTP 25	.Banner Supported commands، وسلوك المستخدمين إذا كان مناسباً.	ابداً: nc.	9200	:Elasticsearch .Version، Cluster Index/Auth .exposure	.curl
RPC/NFS	Files و Exports قد تكشف Configs أو Home أو Keys .data	ابداً: rpcinfo / .showmount	27017	:MongoDB .Version، Auth .Databases	.mongosh

حوّل الدليل إلى الخطوة التالية

بيانات الدخول أو Hash أو المفتاح أو الإصدار هي أدوات توجيه، وليست نهاية المسار.

بيانات دخول نصية

أعد استخدامها فقط على الخدمات التي اكتشفناها فعلاً.

Hash

حدد النوع أولاً، ثم اكسره فقط إذا كان ذلك مفيداً للمسار.

SSH Key

طابق المستخدم والمضيف وصلاحيات الملف الصحيحة.

Config File

استخرج Hostnames و Services و DB/API credentials و Paths.

اختيار الأداة

منفذ مجهول

Nmap - ما الخدمة الموجودة فعلاً؟

منفذ معروف وخدمة مجهولة

Nmap -sV - ما المنتج والإصدار؟

خدمة معروفة

أداة البروتوكول الأصلية - ماذا أستطيع جمعه دون تخمين؟

منتج + نتيجة محددة

Research / SearchSploit - هل توجد مشكلة تطابق هذا السياق تحديداً؟

Module مطابق

Metasploit - اقرأ معلوماته وخياراته ثم تحقق من إعدادات الهدف.

مستخدم معروف + اختبار مصادقة

مبرر

Hydra - فقط عندما يدعم الدليل اختباراً صغيراً ومتحكماً به.

بعد الوصول: استطلع المستخدمين والملفات والواجهات والمسارات. إذا كان الجهاز يرى شبكة لا تصل إليها مباشرة، استخدم Pivot/Tunnel متحكماً به ثم افحص السياق الجديد.